

Reporting and Compliance



Reporting and Compliance

- Documenting and Reporting Security Incidents
- Compliance Monitoring and Audits

Labs

- Ensuring Compliance with Security Policies



Documenting and Reporting Security Incidents

- Documenting and reporting security incidents is a critical component of the Incident Response (IR) lifecycle.
- Proper documentation ensures accountability, regulatory compliance, forensic integrity, operational learning, and continuous security improvement.
- Purpose of Incident Documentation:
 - Create an accurate incident record
 - Support forensic investigation and legal actions
 - Enable management and regulatory reporting
 - Improve future detection and response
 - Preserve institutional knowledge

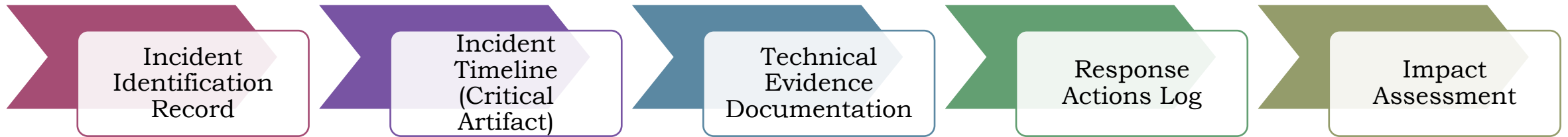


When to Document an Incident?

- At first detection or alert
- During every response phase
- After containment and recovery
- During post-incident review

Rule: If it triggered an IR action, it must be documented.

Incident Documentation Lifecycle



Reporting Stakeholders

■ **Technical Report (SOC / IR Team)**

- Contains:
 - Detailed attack analysis
 - IOCs and TTPs
 - Logs and evidence
 - Recommendations

■ **Management / Executive Report**

- Focus:
 - Business impact
 - Timeline summary
 - Risk exposure
 - Remediation actions

■ **Regulatory and Legal Reporting**

- May require:
 - Breach notification timelines
 - Affected data categories
 - Mitigation steps
 - Evidence preservation

Compliance Monitoring and Audits

- Compliance Monitoring and Audits ensure that an organization's security controls, processes, and technologies continuously meet regulatory, legal, and internal policy requirements.
- **Purpose of Compliance Monitoring**
 - Ensure adherence to regulatory requirements
 - Validate effectiveness of security controls
 - Reduce legal and financial risk
 - Support certifications and audits
 - Demonstrate due diligence to stakeholders



Compliance Monitoring vs Audits

Aspect	Compliance Monitoring	Security Audit
<i>Nature</i>	Continuous	Periodic
<i>Focus</i>	Control effectiveness	Control validation
<i>Approach</i>	Automated + manual	Independent assessment
<i>Output</i>	Dashboards, alerts	Audit reports

Compliance Monitoring Components

- **Policy and Control Mapping**

- Map regulations to internal security controls
- Maintain a control register
- Assign control ownership

- **Continuous Control Monitoring**

- Monitored areas:
 - Patch compliance
 - Endpoint hardening
 - Identity access reviews

- **Configuration and Baseline Compliance**

- Enforce security baselines (CIS, Microsoft)
- Monitor configuration drift
- Remediate deviations

- **Log and Evidence Collection**

- Centralized logging
- Retention per compliance requirements
- Integrity and access controls

Security Audits Lifecycle

- **Audit Planning**

- Define scope and objectives
- Identify applicable regulations
- Establish audit timeline

- **Evidence Collection**

- Policies and procedures
- System configurations
- Logs and reports, Incident records
- Access review results

- **Control Testing**

- Design effectiveness testing
- Operating effectiveness testing
- Sampling and validation

- **Audit Reporting**

- Audit findings
- Risk ratings
- Non-compliance areas
- Recommendations

- **Remediation and Follow-up**

- Corrective action plans
- Risk acceptance documentation
- Re-audits or closure verification





That's all Folks!